

Final Report:

Leading and Managing a Robust and Comprehensive Cybersecurity Program

Taylor Myers

University of Maryland Global Campus

CSIA 300: Cybersecurity for Leaders and Managers

Susan Cole

06/15/2026

7. Privacy Compliance

Privacy compliance is an important part of cybersecurity management because organizations must protect both systems and the personal information connected to those systems. For the Privacy Awareness Training Application, the organization must understand what personally identifiable information is collected, why it is collected, how it is used, who can access it, and how long it should be retained. A Privacy Impact Assessment helps the organization review these issues before privacy risks become larger problems (Department of Defense, n.d.). DD Form 2930 also supports this process because it helps document how personally identifiable information is handled and what controls are used to reduce privacy risks (Department of Defense, n.d.).

The Privacy Awareness Training Application should only collect the information necessary to provide training, track completion, and support compliance reporting. This information may include the username, work email address, employee identification number, job role, department, training completion status, quiz scores, completion dates, and system access logs. The application should not collect Social Security numbers, home addresses, personal financial information, health information, or any unrelated personal data unless there is a clear legal or operational reason and the information is directly tied to the application's purpose (Abassi, 2025). Limiting the information collected helps reduce privacy risk and supports the idea that cybersecurity and privacy protections should be built into organizational processes from the beginning (Abassi, 2025).

One major privacy risk is the overcollection of PII. If the application collects more information than needed, the organization increases the potential harm if the system is compromised. To reduce this risk, the organization should use data minimization, privacy-by-

design principles, and a documented data inventory (Abassi, 2025). Each data element should have a clear purpose. For example, a work email address is needed to send training reminders, but a personal phone number or home address would not be needed for this type of application. This shows that privacy protection must be intentional and connected to the system's actual purpose (Abassi, 2025).

Another major risk is unauthorized access to training records and employee information. Even though training data may not seem as sensitive as financial or medical data, it can still reveal employee roles, department information, compliance gaps, and internal security practices. The organization should reduce this risk by using role-based access control, multifactor authentication, least privilege, and quarterly access reviews (NIST, 2020). Only authorized users, such as compliance officers, system administrators, and managers with a document need to know, should access training completion data. These controls support NIST's guidance on access control, identification, authentication, auditing, and accountability (NIST, 2020).

Improper sharing of PII is another privacy concern. Training data should not be shared outside of the organization unless it is required for compliance, audit, contract, or legal purposes. If an outside vendor supports the application, the vendor should be required to follow written privacy and security requirements (Abassi, 2025; NIST, 2020). These requirements should explain how the vendor protects data, limits access, reports incidents, and destroys information when it is no longer needed. Vendor access should be reviewed at least annually and after any major contract or system change (NIST, 2020). Vendor oversight is important because third-party access can create additional privacy and cybersecurity risk (Abassi, 2025; NIST, 2020).

The organization should also protect PII during storage and transmission. Encryption should be used for data at rest and in transit (NIST, 2020). Audit logs should track access,

changes, failed login attempts, and any exports of training data (NIST, 2020). These logs should be reviewed monthly to identify suspicious behavior. The system should also use secure configuration baselines, patch management, vulnerability scanning, and backup controls to protect the confidentiality, integrity, and availability of the information (NIST, 2020).

Retention is another important privacy issue. The organization should keep training records only as long as needed for compliance, audits, and workforce management (Abassi, 2025). Retention rules should be reviewed at least annually to make sure unnecessary employee data is not being kept longer than needed. Once the retention period ends, the data should be securely deleted or archived according to the organization's records management policy. Keeping unnecessary data for too long increases privacy risk without providing a clear benefit. Overall, the PII risks for the Privacy Awareness Training Application can be reduced through data minimization, access control, encryption, auditing, vendor oversight, and clear retention rules. This connects back to the overall purpose of the report because privacy compliance must be managed continuously across the system lifecycle instead of being treated as a one-time paperwork requirement.

8. Privacy Compliance and Best Practice

Cybersecurity best practices and privacy compliance work together because cybersecurity protects systems, while privacy compliance protects the individuals connected to the data (Abassi, 2025; NIST, 2020). A system can be technically secure but still create privacy concerns if it collects too much information, keeps information too long, or uses data for a purpose that was not clearly explained. For the Privacy Awareness Training Application, cybersecurity controls such as encryption, multifactor authentication, access control, vulnerability management, logging, and incident response help protect user data from unauthorized access

(NIST, 2020). Privacy controls such as data minimization, clear notices, proper retention, and use limitations help make sure the organization handles information responsibly (Abassi, 2025; NIST, 2020). **The NIST Privacy Framework also supports this process because it gives the organization a structured way to identify privacy risks, govern how data is handled, communicate privacy practices, and protect personal information throughout the system lifecycle (NIST, 2020).**

The General Data Protection Regulation, or GDPR, is important because it sets strong privacy expectations for organizations that process personal data connected to individuals in the European Union (European Commission, 2024). Even if the organization is based in United States, GDPR may matter if the application includes EU users or processes EU personal data. GDPR emphasizes principles such as lawfulness, fairness, transparency, purpose limitation, data minimization, accuracy, storage limitation, integrity, confidentiality, and accountability (European Commission, 2024). These principles support the same privacy goals needed for the Privacy Awareness Training Application because the organization must be able to explain what data is collected and how that data is protected (European Commissions, 2024).

U.S. federal privacy laws are also important. The Privacy Act of 1974 applies to federal agencies and focuses on records about individuals that are maintained in a system of records (Winn et al., 2022). This law limits disclosure of personal information without consent unless an exception applies and requires agencies to be transparent about systems that maintain personal records. The E-Government Act of 2002 is also important because it requires Privacy Impact Assessments for federal electronic systems that collect, maintain, or use personal information (Department of Defense, n.d.). This means privacy risks must be reviewed before the system is fully implemented (Department of Defense, n.d.; U.S. Department of Justice, 2022).

Other privacy frameworks may also apply depending on the type of information collected. HIPAA may apply if the system processes protected health information through a covered entity or business associate (U.S. Department of Health and Human Services, 2026). State privacy laws, such as California Consumer Privacy Act, may apply if the organization collects covered personal information from residents of certain states (State of California Department of Justice, 2024). The NIST Privacy Framework can also help the organization manage privacy risk by connecting privacy governance, data processing, communication, and protection activities (NIST, 2020). **For the Privacy Awareness Training Application, this framework is useful because it helps the organization identify what employee data is collected, decide who is responsible for protecting it, explain how the data is used, and monitor whether privacy controls are working. This supports stronger compliance because privacy is managed as an ongoing process instead of only being reviewed after a problem occurs (NIST, 2020).**

The best approach is to combine privacy and cybersecurity into a governance process. Security teams should work with privacy officers, legal staff, system owners, developers, and leadership throughout the system lifecycle. This helps ensure that privacy is not treated as a paperwork requirement, but as part of daily system management. For the Privacy Awareness Training Application, this means privacy should be considered during planning, deployment, testing, development, monitoring, and system retirement. This supports the larger argument that privacy compliance and cybersecurity must be continuously managed across the organization (Abassi, 2025; Wouassom, 2025).

9. COOP Best Practices

A continuity of operations plan is important because organizations must be prepared to continue essential functions during major disruptions. For a large federal organization in the energy sector, a ransomware attack could affect national security, public safety, business operations, and public trust (CISA, 2024; Cyber Security for America, 2026). The energy sector has critical services, so downtime can create consequences beyond one organization. A strong COOP for ransomware must focus on preparation, containment, recovery, and improvement (CISA, 2024; Cyber Strategy for America, 2026).

The first best practice is to identify mission-essential functions before an incident occurs. The organization should identify critical operational systems, business systems, communication systems, emergency response functions, and outside dependencies (CISA, 2024). These systems should be ranked as priority, so recovery efforts focus on the most important services first. This step is important because ransomware incidents can create confusion, and the organization needs to know which systems must be restored first to protect essential operations (CISA, 2024).

The second-best practice is to maintain secure and tested backups. Backups should follow the 3-2-1 rule, which means the organization should keep three copies of critical data, on two diverse types of media, with at least one copy stored offline or in an immutable format (CISA, 2025). Backups should be encrypted, separated from the production network, and tested at least twice per year (CISA, 2025; NIST, 2020). **Critical systems should be backed up daily, and high-priority operational data should be backed up at least every twenty-four hours or more often if the data changes throughout the day. Weekly full backups should also be maintained, with at least one offline or immutable copy so ransomware cannot encrypt or delete it.** A backup that has never been tested should not be trusted during a ransomware event.

Strong backup planning helps the organization recover without depending on damaged or encrypted systems (CISA, n.d.; NIST, 2020).

The third best practice is network segmentation. The organization should separate operational technology from standard business networks. Ransomware can spread quickly when networks are flat and overly connected. Network segmentation, zero trust access, security system rules, and strict remote access controls can reduce the impact of an attack (CISA, 2021; NIST, 2020). Segmentation controls should be reviewed annually and after major network changes. This is especially important in the energy sector because operational technology and business systems may have different risk levels and recovery priorities (CISA, n.d.; NIST, 2020).

The fourth best practice is strong identity and access management. The organization should use multifactor authentication, least privilege, privileged access management, and quarterly account reviews (NIST, 2020). Administrative accounts should be limited, monitored, and separated from normal user accounts. Remote access tools should also be protected with MFA and disabled when not needed. These controls reduce the chance that stolen credentials will allow attackers to move through the environment (NIST, 2020).

The fifth best practice is an alternate communication plan. During a ransomware attack, email, file shares, and internal messaging tools may be unavailable. The COOP should include emergency call trees, updated contact lists, secure alternate communication methods, and procedures for communicating with leadership, employees, CISA, law enforcement, vendors, and energy-sector partners (CISA, 2021; Wouassom, 2025). The communication plan should be tested at least annually during a tabletop exercise. Communication is important because leadership must make decisions quickly when normal systems are disrupted (CISA, n.d.; Wouassom, 2025).

The sixth best practice is to create ransomware response playbooks. These playbooks should explain how to isolate infected devices, preserve evidence, identify affected systems, assess data exposure, restore backups, and report the incident (CISA, 2021; Nelson et al., 2025). The playbooks should also identify who has authority to make major decisions, including system shutdowns, public communications, and external reporting. Written playbooks should be reviewed at least annually and after any ransomware exercise or actual incident. Written playbooks reduce confusion and help the organization respond consistently during a stressful event. Tabletop exercises, technical recovery drills, and full-scale simulations also help teams practice before a real attack occurs (CISA, n.d.; NIST, 2025).

The seventh best practice is to conduct regular exercises. Tabletop exercises should occur at least twice per year, and technical recovery drills should occur at least annually (Boateng, 2024; Wouassom, 2025). These exercises should include executive leadership, legal, privacy, communications, IT, cybersecurity, operations, and emergency management staff. Practicing the COOP also helps the organization find gaps before an actual ransomware incident occurs (Boateng, 2024; Wouassom, 2025).

Finally, the organization should improve after every exercise or real event. Lessons learned should be documented to update the COOP, incident response plan, training, access controls, vendor procedures, and backup strategies. A COOP is only useful if it stays current and reflects the organization's actual systems, risks, and mission needs. This reinforces the main idea that resilience requires continuous planning and improvement across the organization (CISA, 2024; Wouassom, 2025).

10. Training and Cyber Awareness Justification

A strong COOP requires clear responsibilities across multiple job roles. The Chief Information Security Officer should lead the overall cybersecurity strategy, approve incident response priorities, and brief executive leadership (Boateng, 2024; Wouassom, 2025). The CISO should make sure the COOP, incident response plan, cybersecurity policies, and training program are aligned with the organization's mission. The role should complete annual executive cybersecurity training, incident response leadership training, and ransomware tabletop exercises at least twice per year (Boateng, 2024; Wouassom, 2025).

Cybersecurity analysts should monitor alerts, investigate suspicious activity, identify indicators of compromise, and help contain ransomware. They should complete quarterly training in security information and event management tools, endpoint detection and response, malware analysis, threat intelligence, and incident documentation (CISA, 2024). Technical training should occur at least quarterly because ransomware tactics and attack methods change quickly. Analysts also need firsthand exercise at least twice per year so they can practice detection and response before real incident occurs (CISA, 2024).

System administrators should manage patching, backups, account permissions, server recovery, and secure configurations. They should complete annual training on backup restorations, privileged access management, vulnerability remediation, secure system hardening, and disaster recovery (NIST, 2020). System administrators should also participate in recovery drills at least twice per year. This training is important because administrators often control the systems and accounts that attackers target during ransomware events (NIST, 2020).

Software developers should support secure coding, vulnerability remediation, application logging, and secure update practices. Developers should receive secure coding training, OWASP Top 10 training, code review training, and training on the organization's secure development

process and secure software development framework (Souppaya et al., 2022). This training should occur during onboarding and at least annually afterward. Developers should also participate in secure design reviews and vulnerability remediation exercises because software weaknesses can create entry points for attackers (NIST, 2022).

Privacy and compliance officers should ensure that incident response actions also follow privacy laws, reporting requirements, and records management rules. They should complete annual training on privacy impact assessments, breach reporting, data handling, and federal privacy requirements (Abassi, 2025). This role is important because a ransomware attack may involve both system disruption and exposure to personal information. Privacy and compliance officers help make sure the organization responds legally and responsibly (Abassi, 2025).

The communications or public affairs team should prepare internal and external messages during a major disruption. This team should receive annual crisis communication training and participate in at least one tabletop exercise per year so public statements are accurate, timely, and approved through the correct leadership channels (Boateng, 2024; Wouassom, 2025). Clear communication is important because inaccurate or rushed messaging can create confusion, damage trust, or interfere with the investigation (Boateng, 2024; Wouassom, 2025).

All employees should receive cybersecurity awareness training because ransomware often begins with phishing, unsafe links, weak passwords, or social engineering. Employees should complete cybersecurity awareness training at least once a year and participate in phishing simulations at least quarterly (CISA, 2024). Short refresher training should also be provided when new threats appear. Training should focus on phishing, password security, MFA, data handling, incident reporting, and safe remote practices (CISA, 2024).

Regular and updated cybersecurity training is important because threats, technology, and legal requirements continue to change. Training helps employees understand their responsibilities and reduces the chance that one mistake will create a major incident. It also supports good cyber hygiene by reinforcing habits such as reporting suspicious emails, protecting passwords, using MFA, and handling data carefully. Ongoing training also supports the cybersecurity workforce by improving confidence, preparedness, and resilience during high-pressure incidents (DuPont, 2025; Wouassom, 2025). This shows that workforce training is not separate from cybersecurity management; it is one of the main ways an organization keeps cybersecurity active across all roles.

11. Systems Security Management Methodologies

System security should be managed throughout the full system life cycle, not only after deployment. Traditional lifecycle models, Agile, DevOps, DevSecOps, the Microsoft Security Development Lifecycle, and the NIST Secure Software Development Framework all show that security works best when it begins early and continues through maintenance and retirement (Microsoft Security Development Lifecycle Practices, 2026; Souppaya et al., 2022). For the Privacy Awareness Training Application, this is important because the system handles employee information and supports compliance tracking. Security and privacy protections must be included from planning through system retirement (NIST, 2022).

The Microsoft Security Development Lifecycle integrates into development by requiring security activities during requirements, design, implementation, verification, release, and response (Microsoft Security Development Lifecycle Practices, 2026). This helps teams identify security requirements early, perform threat modeling, use secure coding practices, test for

vulnerabilities, and prepare for post-release issues. This model is useful because it treats security as part of the development process instead of something that is added at the end (Microsoft, n.d.).

Agile and DevOps can also support security, but only if security is built into the process. Without security checkpoints, fast development can create weak code, insecure configurations, or missed vulnerabilities. DevSecOps improves this process by adding security testing, code scanning, dependency checks, secrets management, and automated controls into the development pipeline (Souppaya et al., 2022). This allows teams to move quickly while still checking for security and privacy risks (NIST, 2022).

The NIST Secure Software Development Framework also provides useful guidance because it focuses on preparing the organization, protecting software, producing well-secured software, and responding to vulnerabilities (Souppaya et al., 2022). Useful SSDF tasks include defining security requirements, training developers, protecting development environments, reviewing code, using automated tools to find vulnerabilities, maintaining trusted source code, and responding quickly when vulnerabilities are discovered. These tasks help create a structured process for building and maintaining secure applications (NIST, 2022).

The recommended approach for the Privacy Awareness Training Application is a DevSecOps model supported by the NIST SSDF and Microsoft SDL practices (Microsoft Security Development Lifecycle Practices, 2026; Souppaya et al., 2022). This approach allows the organization to develop and update the application efficiently while still requiring security and privacy checks throughout the process. For example, the team should define privacy and security requirements before development, perform threat modeling during design, use code scanning during implementation, and update the application when vulnerabilities are found (Microsoft, n.d.; NIST, 2022).

This approach is the best because the application handles employee PII and supports compliance reporting. Security cannot be treated as a final checklist. It must be part of planning, design, coding, testing, deployment, monitoring, and maintenance. By using DevSecOps, SSDF, and SDL practices together, the organization can make security part of daily development work. This supports the overall point that systems security management must be continuous across the full lifecycle of the system (Abassi, 2025; NIST, 2022).

12. Incident Response Plan Components

For this incident response plan, the public organization selected is the U.S. Department of Energy. This organization is a strong choice because it supports national security, energy security, scientific research, and the protection of critical energy-related systems (Turk et al., 2024). A ransomware attack or major cyber incident affecting the Department of Energy could impact federal systems, energy-sector infrastructure, public trust, and essential services (CISA, 2025; Turk et al., 2024). For this reason, the incident response plan must focus on preparation, leadership, communication, reporting, recovery, and continuous improvement (CISA, 2024; Cyber Strategy for America, 2026).

12.1 Organization Mission

The U.S. Department of Energy supports national security, energy security, scientific research, and the safe operations of critical energy-related systems. For this incident response plan, the focus is the Department's cybersecurity and energy security responsibilities. These responsibilities include protecting federal systems, supporting energy-sectors, partners, and reducing cyber risks that could affect critical infrastructure. The organization's mission requires cybersecurity to be managed as part of daily operations because energy systems are connected to

public safety, economic stability, and national security (CISA, 2024; Cyber Strategy for America, 2026).

12.2 Organization Strategies and Goals

The organization's main strategies are to protect critical systems, strengthen cyber resilience, support energy-sector partners, improve incident detection and response, and reduce the impact of cyber disruptions. A ransomware attack against a federal energy organization could affect business systems, operational technology, communications, research systems, and public trust. Therefore, the incident response program should focus on fast detection, clear communication, containment, recovery, and continuous improvement (CISA, 2024; NIST, 2025).

One goal of the incident response program is to detect and contain cyber incidents as quickly as possible. Another goal is to restore mission-essential functions with minimal downtime. A third goal is to protect sensitive information, including employee information, operational data, and government records. A fourth goal is to improve the organization's response capability after an incident or exercise. These goals show that incident response must be treated as an ongoing organizational responsibility rather than only a technical function.

12.3 Incident Response Leadership

The incident response capability should be led by the CISO or equivalent cybersecurity executive. The incident response team should include cybersecurity analysts, system administrators, network engineers, legal counsel, privacy officers, public affairs staff, emergency management staff, software developers, records management staff, and executive leadership representatives. This structure is important because major incidents affect more than the IT

department. They can also create legal, privacy, operational, communications, and leadership concerns (Boateng, 2024; Wouassom, 2025).

The CISO should coordinate the overall response and brief senior leadership. Cybersecurity analysts should investigate alerts, collect evidence, and identify the scope of compromise. System administrators and network engineers should isolate affected systems and support recovery. Privacy officers should determine whether PII was exposed. Legal counsel should advise on reporting obligations and liability concerns. Public affairs should coordinate approved messaging. Emergency management staff should connect the cyber response to the broader COOP if mission-essential functions are affected (NIST, 2025; Wouassom, 2025). This leadership structure helps the organization respond quickly while still protecting legal, privacy, and operational responsibilities.

12.4 Organizational Approach to Incident Response

The organization should use a structured incident response approach based on preparation, detection, response, and recovery (Nelson et al., 2025). Preparation includes training, playbooks, backups, asset inventories, vulnerability management, communication plans, and tabletop exercises. Detection includes monitoring logs, endpoint alerts, network traffic, user reports, and threat intelligence. Response includes containment, eradication, evidence preservation, communication, and system restoration. Recovery includes validating restored systems, monitoring for reinfection, documenting lessons learned, and improving controls (NIST, 2025).

Best practices should include multifactor authentication, privileged access management, network segmentation, secure backups, endpoint detection and response, centralized logging,

regular patching, phishing training, and secure vendor management (CISA, 2025; NIST, 2020).

The organization should also maintain contact with CISA and other federal partners for threat intelligence and incident coordination. These practices help the organization limit damage, restore systems, and improve future resilience (CISA, n.d.; CISA, 2024; NIST, 2020).

12.5 Reportable Incidents

High-severity incidents include ransomware affecting mission-essential systems, confirmed data exfiltration, compromise of privileged accounts, attacks affecting operation technology, major service outages, or incidents requiring outside agency notification (CISA, 2025; Nelson et al., 2025). These incidents require immediate escalation to senior leadership, legal, privacy, CISA, and other required partners (CISA, n.d.; NIST, 2025).

Moderate incidents include malware infections contained to a limited number of devices, phishing attacks that capture credentials but do not affect critical systems, unauthorized access attempts involving non-critical systems, and suspicious activity requiring investigation. These incidents should be reported to the incident response team and tracked until resolved (NIST, 2025).

Low-severity incidents include blocked phishing emails, failed login attempts, minor policy violations, or malware attempts stopped by security tools before execution. These incidents should still be logged because patterns may show a larger campaign. Tracking low-severity incidents helps the organization identify trends before they become larger problems (NIST, 2025).

12.6 Internal and External Communication

Internal communication should follow a clear chain of command (Nelson et al., 2025; Wouassom, 2025). Employees should report suspicious activity to the help desk or security operations center. The incident response team should update the CISO, legal, privacy, and executive leadership based on severity. During a major outage, the organization should use alternate communication methods such as call trees, secure messaging, or emergency notification systems. This is important because normal email or internal communication systems may be unavailable during ransomware events (NIST, 2025; Wouassom, 2025).

External communication should be coordinated through approved leadership, legal counsel, and public affairs. The organization may need to communicate with CISA, law enforcement, vendors, affected partners, regulators, and the public. Communication should be accurate, timely, and controlled so the organization does not spread incomplete information or interfere with the investigation. Clear communication also helps protect public trust during major cyber incidents (CISA, 2024; NIST, 2025).

12.7 Key Performance Indicators

The organization should measure incident response effectiveness using clear key performance indicators. Useful metrics include mean time to detect, mean time to contain, mean time to recover, number of incidents by severity, percentage of systems covered by endpoint detection, percentage of critical systems with tested backups, phishing click rate, patch compliance rate, tabletop exercise completion rate, and percentage of incidents with completed lessons learned (NIST, 2025; Wouassom, 2025).

These KPIs help leadership understand whether the incident response program is improving. They also show where more staffing, training, tools, or policy changes may be

needed. Measuring incident response performance helps make cybersecurity management more accountable and supports continuous improvement across the organization (Boateng, 2024; Wouassom, 2025).

13. Conclusion

This report shows that cybersecurity management requires more than technical tools. Effective cybersecurity depends on leadership, privacy compliance, workforce training, continuity planning, secure system development, and strong incident response (Boateng, 2024; Wouassom, 2025). Each section connects back to the same main idea: cybersecurity must be managed continuously across the organization rather than treated as a one-time task (Boateng, 2024; Wouassom, 2025).

Privacy compliance frameworks such as GDPR, the Privacy Act of 1974, HIPAA, state privacy laws, and the NIST Privacy Framework help organizations protect user data and maintain accountability (European Commission, 2024; NIST, 2020; OCR, 2026; State of California Department of Justice, 2024; Winn et al., 2022). The Privacy Awareness Training Application must protect PII through data minimization, access control, encryption, auditing, retention limits, vendor oversight, and regular privacy reviews. These controls help reduce privacy risk while also supporting the organization's larger cybersecurity and compliance responsibilities.

The COOP section shows that ransomware planning is especially important for large federal organizations in the energy sector because disruptions can affect national security, public safety, and economic stability. Strong backups, network segmentation, alternate communications, ransomware playbooks, and regular exercises help reduce downtime and

support recovery. These practices show that resilience depends on preparation before an incident occurs and improvement after the incident is resolved (CISA, n.d.; CISA, 2024; Cyber Strategy for America, 2026; NIST, 2020).

The training section shows that cybersecurity is a shared responsibility. Leaders, analysts, administrators, developers, privacy officers, public affairs staff, and employees all need training that matches their roles. Regular and updated training helps maintain cyber hygiene, reduce avoidable mistakes, and prepare employees for real incidents. Training also supports the cybersecurity workforce by helping employees stay prepared and resilient in a stressful threat environment (Boateng, 2024; DuPont, 2025; Wouassom, 2025).

Systems security management is also important because systems must be protected from planning through retirement. A DevSecOps approach supported by NIST SSDF and Microsoft SDL practices give the organization a practical way to build, test, deploy, and maintain secure applications (Microsoft Security Development Lifecycle Practices, 2026; Souppaya et al., 2022). This approach helps ensure that security and privacy are part of the development process instead of being added after the system is already in use (Microsoft, n.d.; NIST, 2022).

Overall, effective leadership is what connects these areas together. Cybersecurity leaders must set expectations, assign responsibility, support compliance, fund-needed controls, and build a culture of continuous improvement. As threats continue to change, organizations must keep adapting their cybersecurity programs instead of treating security as a one-time requirement. Strong leadership, clear planning, privacy compliance, workforce training, secure development, and incident response all work together to help an organization reduce risk and remain resilient (CISA, 2024; Wouassom, 2025).

References:

- Abassi, R. (2025). Refining Ethical Reflections in Cybersecurity Policy and Privacy: Insights for Policy Makers. *J.UCS (Annual Print and CD-ROM Archive Ed.)*, 31(6), 572–602.
<https://doi.org/10.3897/jucs.125999>
- Boateng, S. K. (2024). *A Case Study: What Leadership Competencies Do Cybersecurity Managers Need in the Post-COVID-19 Remote Work Environment* (Order No. 31243486). Available from ProQuest Dissertations & Theses Global; Publicly Available Content Database. (3051297336).
<http://ezproxy.umgc.edu/login?url=https://www.proquest.com/dissertations-theses/case-study-what-leadership-competencies-do/docview/3051297336/se-2>
- CISA. (2024). *CISA Cybersecurity Strategic Plan* | CISA. [Www.cisa.gov. https://www.cisa.gov/cybersecurity-strategic-plan](https://www.cisa.gov/cybersecurity-strategic-plan)
- CISA. (2021, February 1). *Handling Destructive Malware* | CISA. [Www.cisa.gov. https://www.cisa.gov/news-events/news/handling-destructive-malware](https://www.cisa.gov/news-events/news/handling-destructive-malware)
- CISA. (2025). *Ransomware Guide* | CISA. [Www.cisa.gov. https://www.cisa.gov/stopransomware/ransomware-guide](https://www.cisa.gov/stopransomware/ransomware-guide)
- CYBER STRATEGY for America. (2026). <https://www.whitehouse.gov/wp-content/uploads/2026/03/President-Trump-Cyber-Strategy-for-America.pdf>
- DuPont, K. A. (2025). *From Burnout to Resilience: Executive Coaching as a Strategic Intervention in Cybersecurity Workforces* (Order No. 32041470). Available from ProQuest Dissertations & Theses Global. (3205346831).
<http://ezproxy.umgc.edu/login?url=https://www.proquest.com/dissertations-theses/burnout-resilience-executive-coaching-as/docview/3205346831/se-2>
- European Commission. (2024). *Data protection*. [Commission.europa.eu. https://commission.europa.eu/law/law-topic/data-protection_en](https://commission.europa.eu/law/law-topic/data-protection_en)
- Microsoft. (2026). *Microsoft Security Development Lifecycle Practices*. (2026). [Microsoft.com. https://www.microsoft.com/en-us/securityengineering/sdl/practices?msocid=283b6cd7f18468db025c7baef09f6947](https://www.microsoft.com/en-us/securityengineering/sdl/practices?msocid=283b6cd7f18468db025c7baef09f6947)
- National Institute of Standards and Technology. (2020). Security and Privacy controls for information systems and organizations: NIST Special Publication 800-53, Revision 5.
<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf>
- Nelson, A., Rekhi, S., Souppaya, M., & Scarfone, K. (2025). Incident Response Recommendations and Considerations for Cybersecurity Risk Management: *NIST*.
<https://doi.org/10.6028/nist.sp.800-61r3>
- NIST. (2020, January 8). *Privacy Framework*. NIST. <https://www.nist.gov/privacy-framework/privacy-framework>

U.S. Department of Health and Human Services. (2026, March 18). Summary of the HIPPA Privacy Rule. HHS.GOV. <https://www.hhs.gov/hipaa/for-professionals/privacy/laws-regulations/index.html>

Souppaya, M., Scarfone, K., & Dodson, D. (2022, February 3). *Secure Software Development Framework (SSDF) Version 1.1: Recommendations for Mitigating the Risk of Software Vulnerabilities*. Csrc.nist.gov. <https://csrc.nist.gov/pubs/sp/800/218/final>

State of California Department of Justice. (2024). *California Consumer Privacy Act (CCPA)*. State of California - Department of Justice - Office of the Attorney General. <https://www.oag.ca.gov/privacy/ccpa>

The Department of Defense Chief Information Officer (DoW CIO). (2025, February). *Dow Forms Management Program*. Washington Headquarters Services. https://www.esd.whs.mil/Directives/forms/dd2500_2999/DD2930/

Winn, P., Harman-Stokes, K., & Scott, K. (2022, October 12). *Overview of the Privacy Act of 1974 (2020 edition)*. Office of Privacy and Civil Liberties. <https://www.justice.gov/opcl/overview-privacy-act-1974-2020-edition>

Wouassom, T. C. L. (2025). *A Qualitative Analysis of Cybersecurity Leadership on the East Coast of the United States: A Study of Risk Management Strategies* (Order No. 32446000). Available from ProQuest Dissertations & Theses Global. (3325971265). <http://ezproxy.umgc.edu/login?url=https://www.proquest.com/dissertations-theses/qualitative-analysis-cybersecurity-leadership-on/docview/3325971265/se-2>